

RedShield Clinical — Founder Brief

Marco Ortiz Togashi

4 June 2026

CONTENTS

RedShield Clinical — Founder Brief

1. Problem and Status Quo

2. Demand Evidence

3. Target User

4. The Wedge

5. Market (Spain, conservative, bottom-up)

6. Business Model

Key metrics

Operating costs (top 3)

7. Competitor Gap

8. Exit Thesis (3 to 5 years)

9. Regulatory Hook (why the buyer moves now)

10. This Week's Experiment (before Friday)

RedShield Clinical — Founder Brief

A security layer that sits in front of hospital AI agents: red-teaming them and blocking prompt injection, PHI exposure, tool misuse, and data exfiltration, so a clinical agent cannot be tricked into leaking patient data.

Wedge: A one-time adversarial audit of a hospital's live AI agent, delivered as signed evidence for the DPO's mandatory DPIA. €12,000, bookable on one call.

Stage: Pre-revenue, validating. **Beachhead:** Spain, private hospital groups. **Date:** 4 June 2026.

1. Problem and Status Quo

Hospitals are deploying AI agents (clinical documentation, patient-message triage, decision support) on top of patient data. These agents can be prompt-injected, tricked into exposing PHI, misusing tools, or exfiltrating data, turning into a reportable breach under HIPAA (US) or GDPR / LOPDGDD (EU and Spain).

How it is “solved” today, badly:

- Hospitals get the AI vendor to sign a BAA or DPA and assume the contract transfers liability. Nobody tests whether the controls actually hold.
- A single pre-launch review, then nothing. The DPO documents a DPIA on paper but never adversarially tests the agent.
- The regulator confirms the gap: the number one healthcare fine cause in 2025 was inadequate technical measures, and a named failure was software letting staff access more patient data than necessary.

2. Demand Evidence

Honest grade: warm intent, not payment.

- A hospital director in Yanji (family connection) has stated active intent to improve their cybersecurity metrics, signalling budget and an open door.
- A cousin, Judith, a nurse manager, is a warm internal door to reach the actual buyer and to observe real end-user behaviour.
- Regulatory pressure is real and rising: the Spanish DPA (AEPD) issued €40M in fines in 2025, the most aggressive enforcement body in Europe.

No one has paid or begged yet. Converting warm intent into a paid audit is this week's job.

3. Target User

The Chief Privacy Officer / Data Protection Officer (DPO) of a roughly 600-bed hospital in a private group. In Spain the DPO is a legally mandatory role under LOPDGDD, so the buyer always exists.

- **Promoted for:** standing up visible AI governance the board can see.
- **Fired for:** a patient-data leak where they had no mechanism to detect or prevent it.
- **What you sell:** “You will never have to tell the board, or the AEPD, that you had no mechanism.”

4. The Wedge

A one-time adversarial audit of their live AI agent: “here are 11 ways we extracted patient data from your bot,” delivered as a dated, signed PDF that is evidence for the mandatory DPIA. No procurement, no integration, bookable on a single call. €12,000 one-off.

The recurring monitoring product is the expansion, not the wedge. The audit manufactures the demand the subscription needs: nobody buys ongoing monitoring until they have watched their own agent break once.

5. Market (Spain, conservative, bottom-up)

Base facts: Spain has roughly 751 hospitals (449 public/SNS, ~300 private); about 28% (~210) have 200 or more beds; only ~11% of Spanish healthcare practitioners use AI today, with 42% planning to.

Tier	Definition	Value
TAM	All 751 Spanish hospitals at maturity, audit + monitoring (~€25k/yr each)	~€18.8M / year
SAM	~210 hospitals with 200+ beds (DPO, IT budget, will run agents)	~€5.3M / year
SOM	Year 1: ~6 audits + ~4 monitoring conversions	~€120k

The near-term SOM lives in private groups (Quirónsalud, Vithas, HM Hospitales, Ribera), not public SNS hospitals (6 to 18 month public tender cycles).

6. Business Model

- One-off audit (wedge): €12,000.
- Continuous monitoring per facility: €2,500 / month (~€30k/yr).
- Monthly burn (2-person team): ~€13,500 / month.
- Break-even: month 18 to 24.

12-month projection, conservative:

Milestone	MRR	Note
Month 3	€0	First audit lands (€12k one-off)
Month 6	€2,500	First monitoring conversion, MRR begins
Month 12	€10,000	4 recurring customers, ~€117k year-1 revenue

The single metric that decides business vs. freelance gig: audit-to-monitoring conversion rate, currently unproven.

KEY METRICS

- Target CAC: ~€6,000 per recurring customer (warm-intro, founder-led; rises when cold).
- Expected LTV: ~€63k (€2.5k/mo × ~3.5-yr retention × ~60% gross margin).
- LTV/CAC: ~10x headline, ~3 to 4x after haircutting churn, margin, and cold-sales CAC.

OPERATING COSTS (TOP 3)

Cost	€/month	Why unavoidable
People (founder + 1 security engineer)	~€10,000	The audit quality is a skilled human
Insurance + legal + compliance	~€2,000	Cyber liability + indemnity + DPA + ISO path; no DPO signs without it
Compute + tooling	~€1,500	Thousands of attack prompts per engagement

7. Competitor Gap

Competitor	Price	Concrete weakness
Lakera (→ Cisco)	\$99/mo → enterprise custom	Buried in Cisco AI Defense bundle; sold top-down to enterprise CISOs. No LOPDGDD / PHI / Spanish packaging.
Giskard (FR)	Free OSS → custom	Developer / ML tool; output is an engineer's eval report, not a DPIA document a DPO hands the AEPD.
Schellman / HackerOne	From \$16k / engagement	Generic AI red-team service delivered in English from the US; no healthcare-PHI focus, no Article 32 / DPIA framing.

The gap RedShield owns: a PHI-aware audit, in Spanish, delivered as GDPR Article 32 / mandatory-DPIA evidence, buyable as a one-off with no platform and no in-house ML team.

Caveat: the gap is real but its demand is unvalidated. The field may be open because Spanish hospitals are not buying yet, not because nobody thought of it. Only the buyer calls prove demand.

8. Exit Thesis (3 to 5 years)

Acquirer	Concrete reason
Cisco	Already bought Lakera (May 2025) for AI Defense; a PHI/DPIA module with EU-healthcare logos is a clean vertical bolt-on.
Microsoft	Ships the clinical agents (Healthcare Agent Orchestrator, Nuance/DAX, Azure Health); a guardrail that makes its own agents GDPR-safe removes a sales objection.
TÜV SÜD / AENOR (notified body)	The EU AI Act creates a conformity-assessment market for high-risk medical AI; buying RedShield = instant AI-red-team capability. Most European, most realistic exit.

Skeptic's note: at €100k to €180k revenue this is an acqui-hire, not an acquisition. The thesis triggers only at ~€2M to €5M ARR with retained logos. All three acquirers could build instead of buy; the only moat is Spanish-hospital relationships plus regulatory-evidence packaging.

9. Regulatory Hook (why the buyer moves now)

Not the EU AI Act (delayed to high-risk obligations on 2 December 2027; medical-device AI to August 2028; its explicit red-teaming rule targets frontier general-purpose models, not hospital deployers). The live hook is GDPR Article 32 (technical and organisational measures) plus the LOPDGDD mandatory DPIA for large-scale special-category (health) data, enforced today by the AEPD.

Reframe: “Your AI agent is large-scale special-category processing. That triggers a mandatory DPIA and an Article 32 obligation today. Our audit is the evidence that your agent’s controls actually work.”

10. This Week’s Experiment (before Friday)

One concrete, verifiable action: call the Yanji director and ask two qualifying questions.

1. Does your hospital run an AI agent that touches patient data?
2. If I showed you that agent leaking a real patient record, would you pay €12k for a signed audit?

Verifiable outcome: a written yes/no on both questions, plus her reaction to the €12k price, captured the same day.

Output of the week is not code. It is a yes/no to one question: will one real buyer let me attack their agent and pay for the report?